

VAPT Company Framework & Operations

Enterprise Business Setup, Legal Compliance, and End-to-End Penetration Testing Procedures

Executive Overview: This document outlines the structural, legal, and operational blueprint for establishing an independent Vulnerability Assessment and Penetration Testing (VAPT) consultancy firm. It governs risk mitigation, client onboarding, and technical delivery standards.

1. Business Setup & Legal Compliance

Operating a security firm requires stringent legal structures to safeguard both the consultancy and client assets from liability risks during active simulation tests.

Corporate Structure & Insurance

- **Entity Registration:** Form an LLC or Corporation to limit personal professional liability.
- **E&O Insurance:** Secure Errors & Omissions coverage for professional negligence or service disruptions.
- **Cyber Liability:** Protect against accidental system outages or data exposure during testing operations.

Core Legal Agreements

- **NDA:** Mutual protection of client intellectual property and sensitive network topologies.
- **MSA & SOW:** Comprehensive service terms, milestone definitions, and financial terms.
- **Rules of Engagement (RoE):** Explicit legal authorization granting windowed testing permissions.

2. Professional Technical Tooling Stack

Industry-standard toolsets utilized across engagements to ensure reliable and comprehensive vulnerability discovery.

Domain	Core Tools	Primary Purpose
Network & Infra	Nmap, Nessus, Metasploit, Masscan	Port discovery, vulnerability scanning, exploit verification.
Web Apps & APIs	Burp Suite Pro, OWASP ZAP, Postman	Proxy inspection, fuzzing, parameter tampering, API testing.
Mobile Apps	MobSF, Frida, Objection, Genymotion	Static/dynamic analysis, reverse engineering, SSL pinning bypass.
Collaboration	Dradis, Faraday, Custom Markdown Engines	Centralized finding aggregation and streamlined report generation.

3. End-to-End VAPT Operational Workflow

A standardized 6-phase lifecycle ensuring repeatability, minimal disruption, and maximum risk visibility for clients.

Phase	Key Activities	Operational Objective
1. Scoping	- Asset identification (IPs, domains, apps) - Methodology selection (Black/Grey/White)	Define clear testing boundaries and expectations.
2. Authorization (RoE)	- Execute signed RoE & SOW - Whitelist tester IPs; set emergency stop switches	Ensure complete legal compliance and safety.
3. Recon & VA	- Automated vulnerability scanning (Nessus/Nmap) - Architecture mapping and service enumeration	Discover baseline security flaws and open attack surfaces.
4. Exploitation	- Manual validation and vulnerability chaining - Deep-dive attack simulation (avoiding DoS)	Determine true business risk and potential blast radius.
5. Reporting	- CVSS scoring allocation - Executive Summary & Technical Remediation drafting	Deliver clear, actionable data to stakeholders.
6. Retesting	- Patch validation window - Verification scan of previously identified findings	Confirm successful vulnerability remediation.

4. Standard VAPT Report Architecture

Final deliverables are bifurcated to address distinct organizational audiences effectively:

Executive Summary Audience: C-Level / Non-Technical - High-level risk posture and security rating overview. - Quantitative breakdown of findings by severity rating. - Business impact analysis and strategic risk reduction roadmap.	Technical Findings & Remediation Audience: Admins / Developers - Granular vulnerability descriptions with affected endpoints. - Proof of Concept (PoC) logs, screenshots, and CVSS vectors. - Step-by-step developer guidelines for permanent remediation.
--	---